법적 구조

보안프로그램의 진짜 역할 — 은행의 면책 도구

전자금융거래법 제9조

제1항: 금융사고가 나면, **원칙적으로 금융기관이 책임**을 진다.

제2항: 단, "이용자의 고의 또는 중대한 과실"이 있으면, 이용자에게 책임을 전가할 수 있다.

여기서 **"중대한 과실"**이 무엇인지는 은행 약관에 적혀 있다. 은행 약관에는 이렇게 적혀 있다:

```
"금융기관이 제공하는 보안프로그램을
설치하지 않은 경우,
이용자의 중대한 과실로 본다"
```

해석: 보안프로그램을 안 깔면 → 이용자의 중대한 과실 → 금융사고 시 이용자 책임 → **은행 면책**

실제로 벌어지는 일

```
보이스피싱 사고 발생

은행: "보안프로그램 5개 설치하셨습니까?"
피해자: "네, 다 설치했습니다"
은행: "그래도 사고가 났으니,
    보안프로그램을 제대로
    업데이트 안 한 거 아닙니까?"

→ 보안프로그램의 실제 역할:
  ✗ 보이스피싱을 막는 것 (못 막음)
  ✓ "우리는 조치를 했다"는
  면책 근거를 만드는 것
```

EU는 반대로 한다

EU PSD2 (2015년 채택, 2019년 시행):
사고가 나면 **금융기관이 서버 보안을 충분히 했는지**를 본다. "프로그램 깔라고 했으니 우리 잘못 아냐"가 통하지 않는다. **책임이 금융기관에 있으니, 은행이 직접 서버 보안에 투자할 수밖에 없다.**

2020~2025: 바뀌었나?

바뀐 것

2020년 12월: 전자서명법 개정 → 공인인증서 "폐지"
→ 실제로는 **"공동인증서"로 이름만 바꿈.** 기술 구조는 1999년 그대로.

2025년 2월: 전자금융감독규정 개정 → "규칙(Rule) 중심에서 원칙(Principle) 중심으로" 전환 방향 제시

안 바뀐 것

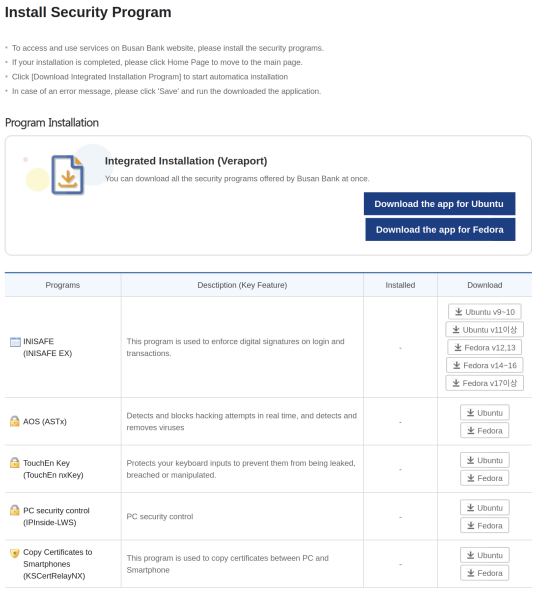
보안프로그램 설치 의무: 아직 완전히 폐지되지 않음

사고 책임 구조: 여전히 이용자에게 전가 가능

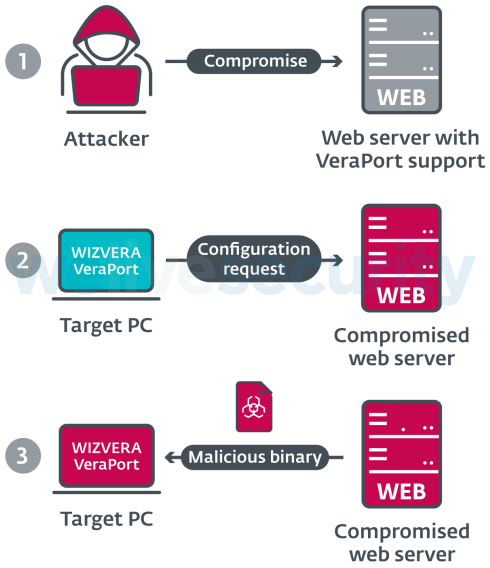
면책 약관: 은행 약관에 "보안프로그램 미설치 = 이용자 과실" 조항 여전히 존재

이미지 테스트

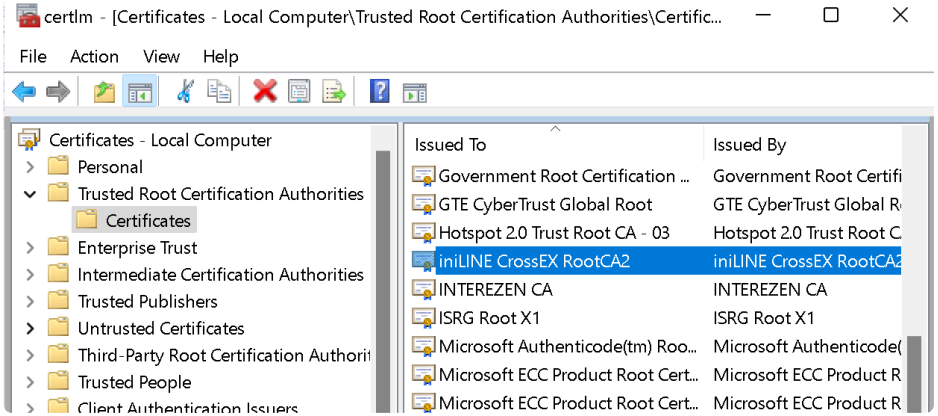
은행 웹사이트에 접속하면 이런 화면이 뜬다



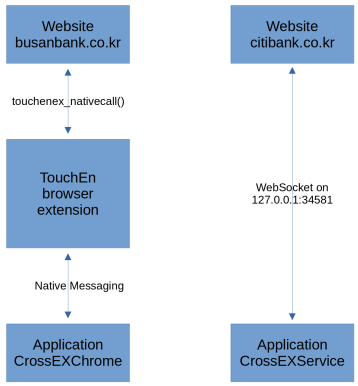
부산은행 보안프로그램 설치 요구 화면 (출처: Palant, 2023)



Lazarus 공격 흐름도 (출처: ESET, 2020)



가짜 인증 기관 (출처: Palant, 2023)



TouchEn nxKey 통신 구조 (출처: Palant, 2023)